

OKTA → PINGFEDERATE · SAML + OIDC

Imagine cutover night. Users sign in to the new IdP... and land on the **wrong account.**

The configuration was right.
The NameID wasn't.

How I built an AI-assisted migration platform that catches this
before cutover.

THE PROBLEM

One migration. Two very different ways to fail.

SAML breaks on

- NameID source and format
- Attribute contracts
- Pinned signing certificates
- Okta expressions with no direct equivalent

OIDC breaks on

- Redirect URIs
- Grant types and PKCE
- Client authentication
- Scopes and claims

And the hardest question comes first: which apps should be migrated at all?

THE DESIGN PRINCIPLE

Rules decide.

DETERMINISTIC

AI reviews.

ADVISORY ONLY

People approve.

HUMAN

The platform verifies.

EVIDENCE

AI is never given authority to invent requirements or make irreversible changes.

THE PIPELINE

Eight stages from Okta to a verified cutover

01 **Discover** apps, claims, groups, certs, 90-day usage

02 **Decide** SP connection / OAuth client mapping, ~30 findings

03 **Review** AI agents challenge every rule result

04 **Approve** versioned plan, four-eyes

05 **Build** dry run, then create-only and disabled

06 **Verify** real sign-in vs Okta baseline

07 **Go / no-go** gate opens only on fresh evidence

08 **Cutover** or rollback to captured Okta values

WAVE PLANNING

Planning is engineering, not a spreadsheet

Score

Complexity × impact from findings, active users, criticality and test environments

Sequence

Low-risk pilot wave first, high-impact apps last

Retire

Unused for 90 days?
Decommission review, not migration

Unblock

Blocked apps tied to named decisions, with a what-if on apps and days saved

Schedule

Effort per app + team capacity + vendor lead time → a timeline with a cutover date per wave, its own build package and app-owner emails

WHERE AI FITS

A tireless second reviewer. **Not an operator.**

AI can

- Agree, raise a concern or disagree with each rule result
- Cite the team's own runbooks
- Explain risk in plain language

AI cannot

- Change a mapping, score or state
- Call Okta or PingFederate
- Approve anything

The AI stack

Claude (Anthropic API) · forced tool use + Pydantic schemas · policy checks that reject invented items or uncited sources · local BM25 retrieval over runbooks · data masking · a fully offline mode

VERIFY BEFORE YOU SWITCH

Evidence, not trust

- Signatures verified with the configured PingFederate certificate, **never the one inside the SAML response**
- Issuer, audience, NameID and attributes diffed against an Okta baseline for the same test user
- Replayed or pre-cutover responses rejected
- Any failure forces a fresh test before the gate reopens
- Rollback values captured from Okta before anything is switched

Live today: SAML validation. Next: OIDC token validation.

THE LESSON

The best use of AI in security automation isn't replacing the decision-maker.

It's a tireless, evidence-based second reviewer around deterministic, approved, auditable controls.

Where would you let AI act on its own in an identity migration, and where would you never let it?

Tell me in the comments.